- When service-to-service API calls are made in response to user requests care should be taken to avoid confused deputy attacks. To avoid this the original user identity should be communicated to backend services. The phantom token pattern provides an efficient way to achieve this in a microservice architecture, while OAuth2 token exchange and macaroons can be used across trust boundaries.

ANSWERS TO EXERCISES

1. d and e. API keys identify services, external organizations, or businesses that need to call your API. An API key may have a long expiry time or never expire, while user tokens typically expire after minutes or hours.
2. e.
3. e. Client credentials and service account authentication can use the same mechanisms, the primary benefit of using a service account is that clients are often stored in a private database that only the AS has access to. Service accounts live in the same repository as other users and so APIs can query identity details and role/group memberships.
4. c, d, and e.
5. e - The CertificateRequest message is sent to request client certificate authentication. If it’s not sent by the server then the client can’t use a certificate.
6. c - The client signs all previous messages in the handshake with the private key. This prevents the message being reused for a different handshake.
7. b.